

# Apex Backend Audit Report

# Table of Contents

**1. Executive Summary .....3**

    About Fystack .....3

    Audit Summary .....3

    Overall Security Posture .....3

    Launch Recommendations .....4

    Audit Scope .....5

**2. Severity Definitions .....7**

    Impact .....7

    Likelihood .....7

    Severity Classification Matrix .....7

    Issue Status .....8

**About Us .....9**

    About Adevar Labs .....9

    Audit Methodology .....9

    Confidentiality Notice .....11

    Legal Disclaimer .....11

# 1. Executive Summary

## About Fystack

Fystack's Apex Backend is the backend service layer for the Apex product. The audited components include API endpoints, authentication and session handling, checkout and payment flows, wallet signing and MPC message handling, webhook functionality, NATS messaging, MongoDB and PostgreSQL configuration, Docker deployment files, and CI/CD configuration.

## Audit Summary

The table below summarizes identified vulnerabilities by risk level and remediation status.

| Risk Level | Count | Fixed | Acknowledged | Won't fix |
|------------|-------|-------|--------------|-----------|
| Critical   | 1     | 1     | 0            | 0         |
| High       | 9     | 6     | 3            | 0         |
| Medium     | 29    | 10    | 13           | 6         |
| Low        | 23    | 0     | 23           | 0         |

Enhancement opportunities: 12

## Overall Security Posture

Fystack's Apex Backend is built on a well-structured architecture with clear separation across its API, storage, messaging, and deployment layers. This audit was a post-launch hardening review. The majority of findings relate to defense-in-depth hardening, secure-configuration defaults, and operational monitoring rather than actively exploitable vulnerabilities. A smaller set of higher-severity findings, concentrated in authentication, secret handling, and cryptographic configuration, were prioritized for remediation. Fystack engaged actively throughout the review: the single Critical finding and the majority of High-severity findings were remediated during the audit window, with the remaining items formally acknowledged and tracked. We recommend resolving the remaining acknowledged High and Medium findings, together with the configuration-hardening items, as part of the ongoing security improvement and release management process.

Fystack does not collect customer data on its servers; external tooling and connections are configured by the customer in config.yaml.

## After Fix Review Summary

During the fix-review phase, Fystack remediated the Critical finding, 6 of 9 High-severity findings, and 10 Medium-severity findings. The remaining findings were reviewed and either formally acknowledged for future remediation or accepted with documented rationale. This represents substantial security progress over the course of the engagement. We recommend continuing to address the acknowledged findings to further reduce the attack surface ahead of and after launch.

## Before Fix Review Summary

The audit identified 1 Critical severity issue. This relates to a hardcoded production credential in Docker Compose.

The audit identified 9 High-severity issues. These include raw internal error exposure, missing message queue error monitoring and DLQ handling, webhook DNS rebinding exposure, legacy AES-CFB support, missing MongoDB authorization, insecure MongoDB sharded cluster authentication, nil salt usage in HKDF, wildcard CORS configuration, and a hard-coded security salt.

The audit identified 29 Medium-severity issues. These include excessive database privileges, unchecked errors, public metrics exposure, non-canonical JSON signing, ignored consumer creation failures.

The audit identified 23 Low-severity issues. These primarily relate to infrastructure and operational hardening, including Docker Compose capability limits, health checks, resource limits, restart policy, container logging.

Additionally, 12 enhancement opportunities were identified. These focus on API documentation and validation through OpenAPI, setup automation, PubSub logic clarity, dead code removal, GitHub Actions timeouts, and MongoDB logging and journaling improvements.

## Launch Recommendations

### After Fix Review Summary

Continue working on the issues to harden as many attack surfaces as possible that were identified throughout the audit.

### Before Fix Review Summary

#### I. Mandatory:

Resolve all Critical and High-severity findings. Add authentication and authorization to all checkout, payment, workspace invitation, webhook verification, and signing-related endpoints. Remove hardcoded credentials and salts from source-controlled files, rotate affected secrets, and move secret loading to a managed runtime secret store.

Add JWT **jti** replay protection, remove legacy AES-CFB support, use non-nil cryptographic salts, and validate all sensitive signing flows against unauthenticated or replayed requests.

Harden data stores and network exposure. Enable MongoDB authorization, require TLS for MongoDB sharded clusters and PostgreSQL communication, restrict CORS origins, protect webhook URL handling against DNS rebinding, and ensure database users follow least-privilege access.

## II. Strongly recommended:

Address the Medium-severity findings that affect production reliability and abuse resistance. This includes improving input validation, pagination, metrics access control, message queue failure handling, NATS encryption, JWT secret validation, Docker image security, GitHub Actions permissions, and PostgreSQL and MongoDB configuration hardening.

Address Low-severity Docker, CI/CD, and logging hardening items. Pin package and action versions, set resource limits and restart policies, add health checks, configure log retention, and improve deployment documentation.

Implement the enhancement opportunities that reduce future security drift. Prioritize OpenAPI specification adoption, automated setup and migration steps, removal of dead code, GitHub Actions timeouts, and improved MongoDB logging and journaling.

## III. Monitoring:

Monitor authentication failures, unauthorized endpoint access attempts, webhook requests, signing operations, JWT replay indicators, and abnormal checkout or payment activity. Add alerts for repeated failures and suspicious request patterns.

Monitor NATS queues, DLQs, consumer creation failures, retry loops, and message processing errors. Forward queue errors and DLQ activity into Grafana or an equivalent alerting system with clear triage ownership.

Monitor MongoDB and PostgreSQL authentication events, failed connections, privilege changes, query errors, TLS enforcement, and log rotation. Review database access logs regularly after deployment.

Continue dependency, container, and CI/CD monitoring. Track Docker image updates, pinned action changes, exposed metrics endpoints, credential rotation status, and newly introduced unauthenticated routes.

## Audit Scope

The audit was performed on the before-fix review commit hash.

- **Repository:** <https://github.com/fystack/apex-backend/>
- **Fix Review Commit Hash:** **afb483f59de64ff5e1ee16065f0f278c1e605b2d**
- **After Fix Review Commit Hash:** **f5f480ccc935380cd3e757084f9607da74936abd**

- **Files/Modules in Scope:**

- fystack-apex-backend/\*

## 2. Severity Definitions

Each issue identified in this report is assigned a severity level based on two dimensions: **Impact** and **Likelihood**. These dimensions help project our team's understanding of both the potential consequences of a vulnerability and how likely a vulnerability is to be discovered and exploited in the real world.

*Note: Enhancements represent non-blocking improvements—typically usability, observability, or defense-in-depth tweaks that do not pose an immediate asset risk but would improve the product's reliability and/or user experience if implemented.*

### Impact

Impact reflects the potential consequences of the issue—particularly on **project funds, user funds**, and the **availability or integrity** of the protocol.

- **High Impact:** Successful exploitation could result in a complete loss of user or protocol funds, disruption of core protocol functionality, or permanent loss of control over critical components.
- **Medium Impact:** Exploitation could cause significant disruption or partial loss of funds, but not a total compromise. May impact some users or non-core functionality.
- **Low Impact:** The issue has minor or negligible consequences. It may affect edge cases, expose metadata, or degrade performance slightly without putting funds or core logic at serious risk.

### Likelihood

Likelihood reflects how easy a vulnerability is to discover and exploit by an attacker, as well as how economically attractive the exploit is to an attacker.

- **High Likelihood:** The vulnerability is trivially exploitable. This means it can be exploited by a wide range of actors without privileged access rights, with minimal capital requirements and low financial risks.
- **Medium Likelihood:** This type of vulnerability can be found and exploited with moderate effort. It might require a significant capital investment, but with manageable financial risk.
- **Low Likelihood:** Exploitation of these vulnerabilities is often technically unfeasible or requires highly specialized conditions. They may require extraordinary effort or a significant financial risk for an attacker, with a high chance of failure and minimal potential return.

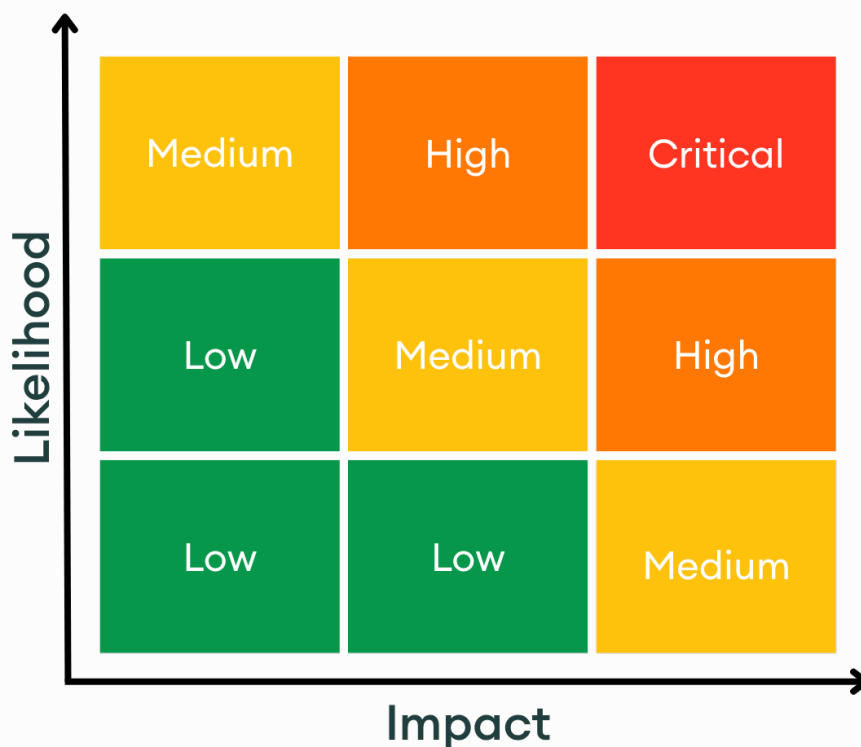
### Severity Classification Matrix

By combining **Impact** and **Likelihood**, we assign a severity level using the matrix below:

- **Critical:** High impact + high likelihood (e.g. a bug that could allow anyone to drain a substantial amount of protocol funds with minimal effort)
- **High:** High impact with medium likelihood, or medium impact with high likelihood
- **Medium:** Moderate impact and/or discoverability

- **Low:** Minimal impact or unlikely to be exploited

This structured approach helps teams prioritize fixes and mitigate the most dangerous threats first.



Severity Matrix

## Issue Status

Each issue is assigned a remediation status to indicate whether the finding has been addressed and how the remaining risk should be interpreted.

- **Open:** The issue has not been remediated, or no fix has been provided for review. The risk described in the finding remains present.
- **Resolved / Fixed:** The issue has been remediated and the fix has been reviewed by Adevar Labs. The original risk is considered addressed based on the reviewed changes.
- **Partially Fixed:** The submitted changes address part of the issue, but some risk, edge case, or recommended remediation step remains outstanding.
- **Acknowledged / Won't fix:** The project team has reviewed the issue and accepts the associated risk, but does not plan to implement a fix at this time.

# About Us

---

## About Adevar Labs

Adevar Labs is a boutique security firm specializing in Web3, infrastructure, and application security audits.

Adevar Labs was built by a mix of experienced traditional enterprise professionals and crypto natives who have contributed to some of the most critical projects in blockchain infrastructure.

Our team's background spans companies like Bitdefender, Asymmetric Research, Quantstamp, Chainproof, and Juicebox, and includes experience securing smart contracts, bridges, L1 and L2 protocols, backend systems, cloud deployments, and production infrastructure.

With over 100 audits completed and a portfolio that includes custom fuzzers, exploit modeling, runtime testing frameworks, and infrastructure review workflows, Adevar Labs brings both depth and precision to every engagement.

Our auditors have discovered critical vulnerabilities, built high-impact tooling, and placed in top positions in premier audit competitions, including Code4rena and Sherlock.

Team members hold distinctions such as PhDs in software protection, key roles at Fortune 500 companies, and leadership of flagship conferences like ETH Bucharest.

With team members whose publications have over 1,100 academic citations and whose work is trusted by projects securing over \$500M in on-chain value, Adevar Labs blends elite technical rigor with real-world security impact.

We also collaborate with some of the best independent security researchers in the Web3 and infrastructure security space.

Projects may optionally request specific contributors to be part of their audit.

## Audit Methodology

Our audit methodology is specialized to provide thorough security assessments of infrastructure, backend deployments, cloud and on-premises environments, CI/CD pipelines, service configurations, and operational security controls. We focus explicitly on rigorous manual analysis, detailed threat modeling, configuration review, and careful validation of implemented fixes to ensure your infrastructure operates securely, reliably, and as intended.

### 1. Infrastructure Context and Architecture Analysis

Our auditors begin by deeply examining your system documentation, configuration files, and operational assumptions. We map out application components, container images, orchestration layers, databases, cloud or on-premises boundaries, and monitoring/logging pipelines.

We also review environment separation, backup and recovery capabilities, high-availability design, network segmentation, firewall rules, scalability assumptions, data integrity expectations, and drift between development, testing, staging, and production deployments.

## 2. Threat Modeling

We conduct targeted threat modeling tailored specifically for infrastructure and backend environments. We carefully define attacker capabilities and identify potential vulnerabilities that may arise from infrastructure-specific issues, including, but not limited to:

- Over-privileged service accounts, weak off-boarding controls, or revocable permissions that are not properly enforced
- Violations in authentication, authorization, access control, and process privileges
- Dangerous defaults, exposed secrets, weak key management, or secret leakage through logs
- Unencrypted communication between services, devices, databases, queues, or administrative interfaces
- Single points of failure, weak high-availability assumptions, insufficient backups, or incomplete recovery procedures
- Cloud, network, firewall, container, and orchestration misconfigurations
- Dev/test environment proximity to production, hidden dependencies, and inconsistent deployment posture

## 3. In-depth Manual Security Review

Our experienced auditors perform an extensive manual security review of your infrastructure and supporting application configuration. We focus on common infrastructure and platform vulnerabilities including, but not limited to:

- API endpoint exposure, authentication gaps, CORS issues, SSRF paths, injection vectors, path traversal, CSRF, DDoS exposure, and uncontrolled resource consumption
- Container and image misconfigurations, embedded secrets, hidden dependencies, outdated base images, missing runtime isolation, and unsafe process privileges
- CI/CD weaknesses across GitHub Actions, Bitbucket Pipelines, Jenkins, and similar systems, including excessive permissions, secret exposure, and unsafe software update mechanisms
- Database, cache, queue, and service discovery configuration issues
- Firewall and network policy weaknesses
- Monitoring, alerting, log coverage, and log leakage issues across tools such as Grafana

During this stage, we clearly document any discovered vulnerabilities, including detailed descriptions, precise severity ratings, and recommendations for secure implementation. In situations where it is not clear how the vulnerability might be exploited, we may also include a detailed proof-of-concept exploit with code snippets and instructions on how the exploit could be performed.

## 4. Detailed Fix Review and Validation

After the initial audit and your team's subsequent remediation efforts, we perform a comprehensive fix review to ensure the vulnerabilities identified have been effectively resolved.

We verify each fix individually, confirming that:

- Corrections effectively eliminate the security risks
- Changes do not inadvertently introduce new vulnerabilities or regressions
- The fixes align closely with infrastructure and operational security best practices

Our detailed validation ensures that security improvements are robust, complete, and aligned with best practices.

## Confidentiality Notice

This report, including its content, data, and underlying methodologies, is subject to the confidentiality and feedback provisions in your agreement with Adevar Labs. These materials are not to be disclosed, extracted, copied, or distributed except to the extent expressly authorized by Adevar Labs.

## Legal Disclaimer

The review and this report are provided by Adevar Labs on an as-is, where-is, and as-available basis. To the fullest extent permitted by law, Adevar Labs disclaims all warranties, express or implied, in connection with this report, its content, and your use thereof, including, without limitation, the implied warranties of merchantability, fitness for a particular purpose, and non-infringement.

You agree that access to and/or use of the report and other results of the review, including any associated services, products, protocols, platforms, content, and materials, will be at your sole risk.

FOR THE AVOIDANCE OF DOUBT, THE REPORT, ITS CONTENT, ACCESS, AND/OR USAGE THEREOF, INCLUDING ANY ASSOCIATED SERVICES OR MATERIALS, SHALL NOT BE CONSIDERED OR RELIED UPON AS ANY FORM OF FINANCIAL, INVESTMENT, TAX, LEGAL, REGULATORY, OR OTHER ADVICE. This report is based on the scope of materials and documentation provided for a limited review at the time of review.

You acknowledge that software, infrastructure, and blockchain technology remain under development and are subject to unknown risks and flaws. Adevar Labs does not warrant, endorse, guarantee, or assume responsibility for any product or service advertised or offered by a third party, or any open-source or third-party software, code, libraries, materials, or information accessible through the report. As with the purchase or use of a product or service in any environment, you should use your best judgment and exercise caution where appropriate.